

(b) GUÍA METODOLÓGICA DETALLADA DE LA ENCUESTA MARGA-ENS

1. Objeto de la guía

Esta guía describe la lógica, el uso y la interpretación de la encuesta MARGA-ENS sobre indicadores y métricas de ciberseguridad y ciberresiliencia en organizaciones públicas y privadas alineadas con el Esquema Nacional de Seguridad (ENS). Se inspira en el proceso de adecuación ENS, en el proyecto INES para informar sobre el estado de seguridad y en el modelo IMC de indicadores para la mejora de la ciberresiliencia.[web:19][web:16][web:27][web:35]

La encuesta no pretende ser un examen, sino un espejo: su objetivo es proporcionar una imagen honesta del grado de implantación de prácticas de medición, para facilitar decisiones estratégicas de mejora.

2. Alcance y población objetivo

La encuesta está dirigida a:

- Organismos y entidades sujetos al ENS (AGE, CCAA, entidades locales, organismos públicos y su sector público instrumental).
- Empresas privadas, especialmente aquellas sujetas a NIS2, DORA u otras regulaciones que exigen capacidades de ciberresiliencia e indicadores formales.
- Proveedores de servicios y operadores de servicios esenciales o infraestructuras críticas, especialmente aquellos que utilizan el modelo IMC de ciberresiliencia.[web:27][web:35][web:12]

El respondente ideal es el CISO o responsable de seguridad de la información; en su defecto, un responsable TIC o de riesgos con visión transversal.

3. Estructura general de la encuesta

La encuesta se organiza en diez bloques coherentes con:

- El ciclo ENS (plan de adecuación, implantación, auditoría e información de estado).[web:19]
- El modelo IMC (metas Anticipar, Resistir, Recuperar, Evolucionar).[web:27]
- Las recomendaciones de marcos internacionales para KPIs/KRIs y Zero Trust.[web:20][web:39]

Cada bloque responde a una pregunta básica:

1. ¿Quién es usted y en qué contexto opera? (Información general)
2. ¿Cómo se gobierna la seguridad y la adecuación ENS en su organización? (Gobernanza ENS)
3. ¿Qué papel juegan el riesgo y los indicadores en su ciclo ENS? (Riesgos e indicadores)
4. ¿Qué tan resiliente es, según el prisma IMC? (Ciberresiliencia)
5. ¿Qué tan eficaz es operativamente? (Vulnerabilidades, incidentes, MTTD, MTTR)
6. ¿Avanza hacia Zero Trust o sigue confiando en el perímetro? (Arquitectura)
7. ¿Existe cultura de seguridad o solo carteles motivacionales? (Formación)
8. ¿Puede seguir funcionando cuando todo falla? (Continuidad y recuperación)
9. ¿Entiende el riesgo también en euros y no solo en siglas? (Riesgo, IGM y ROI)
10. ¿Cómo percibe, en conciencia, la adecuación de sus indicadores? (Perspectiva del responsable)

4. Tipo de preguntas y escalas de respuesta

La encuesta utiliza principalmente:

11. Preguntas cerradas de selección única, para facilitar la codificación estadística y comparabilidad.
12. Preguntas cerradas de selección múltiple, para captar variedad de prácticas.
13. Preguntas abiertas, usadas con mesura, para recoger matices cualitativos.

Las escalas preferentes son:

- Porcentajes aproximados (0–25, 26–50, 51–75, 76–95, 96–100) para madurez de despliegues.
- Frecuencias (mensual, trimestral, anual, ad hoc) para prácticas de reporting y pruebas.
- Intervalos de tiempo (minutos, horas, días, semanas) para MTTD y MTTR.
- Escalas de 1 a 5 para percepciones subjetivas (adecuación de indicadores, etc.).

Esta combinación permite, por un lado, alimentar análisis cuantitativos (tendencias, correlaciones, comparaciones sectoriales) y, por otro, no perder la riqueza cualitativa que tanto irrita a las hojas de cálculo como ilumina a los comités de dirección.

5. Lógica de diseño por bloques

5.1. Gobernanza ENS y adecuación

Este bloque se fundamenta en los requisitos del ENS relativos a política de seguridad, categorización de sistemas, análisis de riesgos, declaración de aplicabilidad y organización de la seguridad.[web:26]

[web:19] Las preguntas persiguen:

- Comprobar si la entidad ha realizado los pasos básicos del plan de adecuación.
- Medir la cobertura de la categorización y la formalización de la DoA.
- Identificar el grado de alineamiento entre ENS y la gobernanza real (no sólo nominal).

Interpretación recomendada:

- Un alto porcentaje de sistemas categorizados y una DoA implantada son indicadores positivos, pero deben contrastarse con bloques posteriores (indicadores y ciberresiliencia).
- Una respuesta “en elaboración” recurrente sugiere riesgo de “adecuación perpetua” y dificultad para consolidar métricas.

5.2. Riesgos, indicadores y ciclo ENS

El ENS exige informar sobre el estado de seguridad mediante métricas e indicadores, y el CCN ha desarrollado el proyecto INES precisamente para ello.[web:16][web:19] Este bloque explora:

- Existencia y madurez del cuadro de mando de seguridad.
- Frecuencia y alcance de la información a la Alta Dirección.
- Cobertura temática de los indicadores (cumplimiento, vulnerabilidades, incidentes, etc.).

Interpretación:

- Ausencia de cuadro de mando o reporting es un síntoma de ENS “cosmético”: controles sin dirección ni priorización.
- Un cuadro de mando excesivamente técnico puede indicar desconexión con la agenda de riesgos corporativos.

5.3. Ciberresiliencia según IMC

INCIBE, a través del Diccionario de Indicadores para Mejora de la Ciberresiliencia, ha establecido un modelo robusto y reutilizable de indicadores por metas y dominios funcionales.[web:27][web:35] La encuesta analiza:

- Nivel de conocimiento y uso del modelo IMC.
- Implantación de indicadores por meta (Anticipar, Resistir, Recuperar, Evolucionar).

Interpretación:

- Uso explícito del IMC sugiere un enfoque más maduro y alineado con las tendencias europeas en materia de ciberresiliencia.
- Fuerte asimetría entre metas (por ejemplo, mucha protección, poca recuperación) anticipa déficit en continuidad y pruebas.

5.4. Eficacia operativa (KPIs/KRIs)

Este bloque se inspira tanto en prácticas internacionales como en propuestas de marcos estandarizados de indicadores para CISOs, que subrayan la importancia de KPIs y KRIs estratégicamente relevantes, medibles y comparables.[web:20][web:12] Se centra en:

- Gestión de vulnerabilidades (número, criticidad, tiempos de parcheado).
- Medición de MTDD y MTTR.
- Registro y análisis de incidentes y sus impactos.

Interpretación:

- Ausencia de MTDD/MTTR medidos indica que la organización “sufre” incidentes, pero no los estudia.
- La no estimación de impactos dificulta hablar seriamente de ROI y priorización de inversiones.

5.5. Zero Trust y arquitectura

Las guías y artículos sobre Zero Trust del NIST, de la industria y de organismos como INCIBE destacan la necesidad de pasar de perímetros a modelos centrados en identidad, contexto y verificación continua.

[web:6][web:14][web:10] Este bloque pregunta:

- Si existe estrategia explícita de Zero Trust.
- Qué elementos concretos están ya implantados.
- Si se miden esos avances como indicadores.

Interpretación:

- Adoptar MFA aislada no convierte a nadie en Zero Trust, pero al menos indica cierta orientación.
- Indicadores de porcentaje de recursos protegidos o de accesos verificados son una señal clara de madurez arquitectónica.

5.6. Formación, cultura y comportamiento

La formación y concienciación, aunque a menudo relegadas a la categoría de “actividades simpáticas”, son un componente esencial de la ciberresiliencia. El bloque explora:

- Existencia de un plan formal de formación.
- Registro de participación y resultados.
- Uso de pruebas de comportamiento (p. ej. phishing simulado).

Interpretación:

- La ausencia completa de indicadores de formación sugiere que la organización confía más en la suerte que en la educación.
- Un programa maduro vincula resultados de formación con reducción de incidentes humanos.

5.7. Continuidad y recuperación

Las estrategias sectoriales de ciberseguridad, especialmente en ámbitos como sanidad, insisten en la continuidad de servicios esenciales frente a incidentes de ciberseguridad.[web:30] Este bloque examina:

- Existencia y alcance de BCP/DRP.
- Periodicidad de pruebas.
- Medición de resultados (RTO/RPO reales vs. objetivos).

Interpretación:

- Planes no probados son literatura.
- La medición sistemática de desviaciones tras pruebas es un indicador potente de madurez.

5.8. Riesgo, IGM y ROI

Por último, el bloque económico conecta con la tendencia internacional a tratar el riesgo cibernético como riesgo empresarial, con informes como el Global Cybersecurity Outlook señalando impactos económicos y geopolíticos crecientes.[web:11][web:12] La encuesta se interesa por:

- Cuantificación del riesgo en términos económicos.
- Presencia de ciberseguros.
- Cálculo de índices de madurez global (IGM) y ROI.

Interpretación:

- La falta de cuantificación económica limita seriamente la conversación con la Alta Dirección.
- La existencia de un índice de madurez global permite integrar múltiples indicadores y facilitar comparaciones en el tiempo y entre unidades.

6. Administración de la encuesta

6.1. Modalidad

Se recomienda administración en línea (formulario web o herramienta de encuestas) con las siguientes condiciones:

- Invitación nominativa a responsables de seguridad y equivalentes.
- Posibilidad de guardar y continuar más tarde (la encuesta es detallada).
- Posibilidad de adjuntar documentación complementaria si se desea.

6.2. Tiempo estimado

Dependiendo del nivel de madurez y del acceso a la información, el tiempo estimado oscila entre 30 y 60 minutos. Si la organización tarda mucho más, es una señal indirecta de que la información no está centralizada... lo cual, por cierto, también es un resultado interesante.

6.3. Confidencialidad y uso de datos

Los resultados deben tratarse como información sensible. Se recomienda:

- Anonimizar los resultados en informes agregados.
- Evitar publicar datos identificables de organizaciones individuales sin su consentimiento.
- Utilizar los resultados primariamente para diagnóstico y planificación de mejoras, no para exhibiciones públicas.

7. Tratamiento y análisis de resultados

Una vez recopiladas las respuestas:

14. Codificación: asignar valores numéricos a las opciones de respuesta (p. ej. 1–5 para niveles de madurez).
15. Cálculo de indicadores derivados: generar índices parciales por bloque (gobernanza, ciberresiliencia, arquitectura, etc.).
16. Construcción de un IGM (Índice Global de Madurez): agregando bloques con ponderaciones razonables (ver plantilla en el documento (e)).
17. Análisis comparativo: por sector, tamaño, ámbito público/privado, etc.
18. Identificación de patrones: correlaciones entre, por ejemplo, existencia de IMC y tiempos de respuesta, o entre Zero Trust y reducción de incidentes.

El objetivo es pasar de un conjunto de respuestas aisladas a una narrativa de país: en qué somos fuertes, dónde somos estructuralmente débiles, y qué reformas o inversiones deben priorizarse.

8. Limitaciones y precauciones

- Autorreporte: la encuesta se basa en la declaración de los responsables, con el riesgo de sesgo optimista o defensivo. Se recomienda contrastar resultados con auditorías y evidencias objetivas.
- Heterogeneidad: organizaciones de tamaños y sectores muy distintos tendrán realidades difícilmente comparables; la solución es agrupar por tipologías, no forzar comparaciones injustas.
- Evolución normativa: ENS, NIS2, DORA y otros marcos evolucionan; la encuesta debe revisarse periódicamente para seguir siendo relevante.[web:26][web:12]

9. Conclusión

Medir no es una manía estadística, sino una forma de respeto a la realidad. La encuesta MARGA-ENS aspira a convertir la intuición en evidencia, la queja en mejora y el “creemos que vamos bien” en “sabemos dónde estamos”. El resto es cuestión de voluntad... y de presupuestos, por supuesto.